

Security Testing - Next Steps Guide

Date: April 23, 2026

Status:  All security fixes implemented and committed

Ready for: Re-testing with OWASP ZAP

What Was Accomplished

 Security Fixes Completed

10 vulnerabilities resolved:

- 5 Medium-risk issues (CSP configuration)
- 5 Low-risk issues (headers and cookies)

Files modified:

- `Middleware/SecurityHeadersMiddleware.cs` - Enhanced security headers
- `Program.cs` - Server configuration and cookie settings

Build status:  Success (0 errors, 1 pre-existing warning)

Git status:  Committed (1da5db8) and pushed to GitHub

Testing Instructions

Step 1: Local Application Test

Test that the application still works with new security settings:

```
# 1. Navigate to project directory
cd "/Users/cruZR/Documents/ISM Sponsor"

# 2. Run the application
dotnet run

# 3. Visit in browser:
# - https://localhost:5001/
# - https://localhost:5001/Account/Login
# - https://localhost:5001/api/docs
```

Verify these work:

-  Application loads
-  Login page displays
-  CSS and JavaScript load correctly
-  Login works (use admin/Admin@123)

-  Forms submit correctly
-  Swagger UI loads

Step 2: Verify Security Headers

Using Browser DevTools:

1. Open DevTools (F12)
2. Go to Network tab
3. Refresh page
4. Click on the main document request
5. Check Response Headers

Expected headers:

```
Content-Security-Policy: default-src 'self'; script-src 'self'; ...
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
X-XSS-Protection: 1; mode=block
```

Should NOT see:

```
Server: Kestrel          ← SHOULD BE REMOVED
X-Powered-By: ASP.NET    ← SHOULD BE REMOVED
```

Cookie headers should show:

```
Set-Cookie: ...; SameSite=Lax; HttpOnly; Secure
```

Step 3: Run ZAP Security Scan Again

Option A: Manual ZAP Scan

1. **Start ZAP application**
2. **Set target:**
 - For local: <https://localhost:5001>
 - For Azure: <https://ismsponsor.azurewebsites.net>
3. **Run Automated Scan:**
 - Quick Start → Automated Scan
 - Enter URL
 - Click "Attack"
4. **Generate Report:**
 - Report → Generate HTML Report

- Save as: **ZAP_Scan_After_Fixes_2026-04-23.html**

5. **Compare results** with original scan

Option B: ZAP Automation (if configured)

```
# Using ZAP CLI or API
zap-cli quick-scan --self-contained https://localhost:5001
```

Step 4: Deploy to Azure (if local tests pass)

```
# If already configured for Azure deployment
git push

# Azure will automatically deploy the latest commit
# Wait 2-3 minutes for deployment to complete
```

Then run ZAP scan against Azure URL:

```
Target: https://ismsponsor.azurewebsites.net
```

Expected ZAP Results

Before Fixes (Original Scan)

	High:	0	
	Medium:	5	← CSP issues
	Low:	5	← Headers & cookies
	Informational:	5	

After Fixes (Expected)

	High:	0	 (no change)
	Medium:	0	 (was 5 – all fixed)
	Low:	0	 (was 5 – all fixed)
	Informational:	5	 (no change – expected)

Specific Issues That Should Now PASS

Medium Risk - Should all be RESOLVED:

1.  CSP: Failure to Define Directive with No Fallback
2.  CSP: Wildcard Directive
3.  CSP: script-src unsafe-eval
4.  CSP: script-src unsafe-inline
5.  CSP: style-src unsafe-inline

Low Risk - Should all be RESOLVED: 6.  Cookie with SameSite Attribute None 7.  Cookie without SameSite Attribute 8.  Server Leaks Information via "X-Powered-By" 9.  Server Leaks Version Information via "Server" 10.  Strict-Transport-Security Header Not Set

Troubleshooting

If CSP blocks functionality:

Symptom: Scripts or styles not loading, console errors like:

```
Refused to execute inline script because it violates Content-Security-Policy directive
```

Solution: Check browser console for specific CSP violations and adjust CSP in SecurityHeadersMiddleware.cs

Temporary workaround (for testing only):

```
// In SecurityHeadersMiddleware.cs, temporarily add 'unsafe-inline' back  
"script-src 'self' 'unsafe-inline';"
```

If HSTS causes issues:

Symptom: Cannot access http:// version of site

Solution: This is expected behavior - HSTS forces HTTPS. To clear HSTS in browser:

- Chrome: Visit <chrome://net-internal/#hsts> and delete domain
- Firefox: Clear browsing history including active logins

If cookies don't work:

Symptom: Login doesn't persist, session lost

Solution:

1. Check that HTTPS is enabled
2. Verify cookie settings in appsettings.json:

```
{
  "Security": {
    "CookieSecurePolicy": "SameAsRequest"
  }
}
```

Verification Checklist

Before running ZAP scan, verify:

- ☐ Application builds without errors
- ☐ Application starts successfully
- ☐ Home page loads
- ☐ Login functionality works
- ☐ Static files (CSS, JS, images) load
- ☐ Forms submit correctly
- ☐ Session management works
- ☐ API endpoints respond
- ☐ Swagger UI loads
- ☐ No console errors related to CSP
- ☐ Security headers present in response

Documentation Files

1. **Security Analysis:** [docs/ZAP_Security_Analysis_2026-04-23.md](#)

- Original ZAP scan analysis
- All vulnerabilities documented
- Recommendations provided

2. **Security Fixes Report:** [docs/Security_Fixes_Report_2026-04-23.md](#)

- Detailed fix implementation
- Before/after comparisons
- Code changes documented

3. **Original ZAP Report:** [\[docs/ZAP Reports/ZAP by Checkmarx Scanning Report.html\]\(docs/ZAP Reports/ZAP by Checkmarx Scanning Report.html\)](#)

- HTML report from initial scan
- Baseline for comparison

Post-Test Actions

If ZAP Scan Passes (Expected):

1. Update test reports:

- Add ZAP retest results to documentation
- Document that all issues resolved
- Update security grade (B → A+)

2. Update HANDOFF document:

- Note security hardening completed
- Add ZAP scan results
- Update production readiness checklist

3. Prepare for capstone:

- Security improvements are demo-ready
- Can highlight A+ security grade
- Show before/after ZAP reports

If ZAP Scan Finds Issues (Unexpected):

1. Review new findings:

- Check if legitimate issues or false positives
- Compare with original scan

2. Address remaining issues:

- Update SecurityHeadersMiddleware.cs if needed
- Adjust CSP if required
- Document decisions

3. Re-test:

- Fix issues
- Run ZAP scan again
- Verify all clear

Commands Quick Reference

```
# Navigate to project
cd "/Users/cruZR/Documents/ISM Sponsor"

# Build
dotnet build

# Run locally
dotnet run

# Check git status
git status
```

```
# View latest commit
git log --oneline -1

# Check running processes
lsof -ti:5000

# Kill process on port 5000
lsof -ti:5000 | xargs kill -9

# Push to GitHub
git push
```

Success Criteria

Application is ready for retest when:

- ✓ All items in Verification Checklist are complete
- ✓ No security-related console errors
- ✓ Security headers verified in browser
- ✓ Application functionality fully working
- ✓ Ready to run ZAP automated scan

Security fixes are successful when:

- ✓ ZAP scan shows 0 Medium risk issues (was 5)
- ✓ ZAP scan shows 0 Low risk issues (was 5)
- ✓ No new high or medium risk issues introduced
- ✓ Application functionality unchanged
- ✓ Security grade improved to A+

Report Prepared By: Security Implementation Team

Date: April 23, 2026

Status: READY FOR VERIFICATION TESTING

Next Review: After ZAP retest completion

Contact & Support

If issues occur:

1. Check troubleshooting section above
2. Review Security_Fixes_Report for detailed changes
3. Use git to revert if necessary: `git checkout HEAD~1`

Remember: All changes are committed to git (commit 1da5db8) and can be rolled back if needed.